



ISC 互联网安全大会



360 互联网安全中心

基于AI的云安全治理

王雨晨

华为网络安全解决方案首席架构师

2018 ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

(原“中国互联网安全大会”)

目录

信息安全的变与不变

安全对抗的制胜之道

华为基于AI的云安全实践

从信息安全的角度，能看到什么？

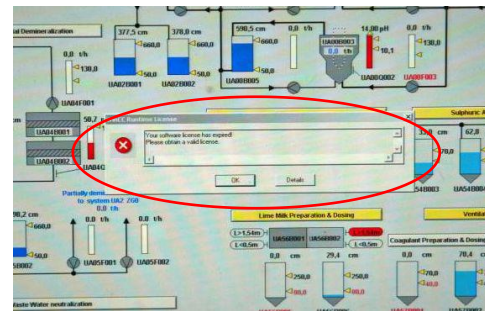
Closed Transactions:

Tidlet	Open Time	Type	Size	Item	Price	S / L	T / P	Close Time	Price	Commission	Taxes	Swap	Profit
152344812	2012.01.18 17:32	balance	Deposit					2012.01.19 16:04	1.54460	0.00	0.00		5 400.00
152345000	2012.01.18 17:35	buy	2.00	gbpsd	1.54204	1.53900	0.00000	2012.01.19 16:04	1.54460	0.00	0.00		-492.00
152518339	2012.01.18 17:35	buy	0.50	gbpsd	1.54204	1.54204	0.00000	2012.01.20 05:01	1.54070	0.00	0.00		-6.15
152521154	2012.01.19 16:20	sell	0.10	gbpsd	1.54366	1.54661	0.00000	2012.01.19 17:44	1.54661	0.00	0.00		-29.50
152596032	2012.01.18 17:35	buy	0.50	gbpsd	1.54204	1.54204	0.00000	2012.01.20 12:43	1.54596	0.00	0.00		-6.15
152697669	2012.01.20 17:00	sell	0.10	gbpsd	1.55381	1.55380	0.00000	2012.01.20 17:37	1.55380	0.00	0.00		-19.90
152781193	2012.01.20 18:13	buy	0.10	gbpsd	1.55947	1.55260	0.00000	2012.01.21 10:36	1.55260	0.00	0.00		-28.70
152817076	2012.01.23 12:02	buy	0.10	gbpsd	1.55943	1.55943	0.00000	2012.01.24 14:11	1.55987	0.00	0.00		-4.40
153018709	2012.01.24 14:11	sell	2.00	gbpsd	1.55611	1.56100	0.00000	2012.01.24 14:30	1.55819	0.00	0.00		-376.00
153018771	2012.01.24 14:12	sell	2.00	gbpsd	1.55637	1.56100	1.54657	2012.01.24 14:30	1.55816	0.00	0.00		-356.00
153021881	2012.01.24 14:30	buy	3.00	gbpsd	1.55815	1.55317	0.00000	2012.01.24 15:37	1.55704	0.00	0.00		-333.00
153036520	2012.01.24 15:38	sell	1.00	gbpsd	1.55713	1.56070	0.00000	2012.01.24 16:00	1.55980	0.00	0.00		-177.00
153042702	2012.01.24 16:00	buy	2.00	gbpsd	1.55644	1.55626	0.00000	2012.01.25 10:36	1.55626	0.00	0.00		-6.40
153045690	2012.01.24 16:15	sell	1.00	gbpsd	1.55651	1.55651	0.00000	2012.01.25 10:36	1.55551	0.00	0.00		-3.20
153149412	2012.01.25 11:35	buy	2.00	gbpsd	1.55725	1.55725	0.00000	2012.01.25 11:49	1.55769	0.00	0.00		264.00
153159494	2012.01.25 11:35	buy	2.00	gbpsd	1.55725	1.55711	0.00000	2012.01.25 14:01	1.55711	0.00	0.00		74.00
153176902	2012.01.25 14:01	sell	2.00	gbpsd	1.55709	1.56030	0.00000	2012.01.25 14:12	1.55706	0.00	0.00		2.00
153176962	2012.01.25 14:01	sell	4.00	gbpsd	1.55709	1.56090	1.54490	2012.01.25 15:36	1.55844	0.00	0.00		46.00
153179711	2012.01.25 16:02	sell	0.12	gbpsd	1.55993	1.56000	0.00000	2012.01.25 16:05	1.55769	0.00	0.00		-9.12
153198336	2012.01.25 16:05	buy	1.00	gbpsd	1.55743	1.55320	0.00000	2012.01.25 16:08	1.55760	0.00	0.00		7.00
153198685	2012.01.25 16:07	buy	2.00	gbpsd	1.55766	1.55320	1.56760	2012.01.25 22:48	1.56760	0.00	0.00		1 988.00
153479774	2012.01.27 02:37	sell	2.00	gbpsd	1.56732	1.57400	0.00000	2012.01.27 02:47	1.56731	0.00	0.00		2.00
153474211	2012.01.27 02:37	buy	1.00	gbpsd	1.56732	1.57400	0.00000	2012.01.27 02:50	1.56713	0.00	0.00		19.00
153474802	2012.01.27 02:37	sell	0.50	gbpsd	1.56732	1.57400	1.55732	2012.01.27 12:01	1.57179	0.00	0.00		-323.50
153477949	2012.01.27 10:19	sell	1.00	gbpsd	1.57000	1.57400	0.00000	2012.01.27 11:36	1.56965	0.00	0.00		35.00
153395227	2012.01.27 02:37	sell	0.50	gbpsd	1.56732	1.57400	1.55950	2012.01.27 22:20	1.57400	0.00	0.00		-334.00
153564395	2012.01.27 14:33	sell	0.50	gbpsd	1.56695	1.57400	1.55950	2012.01.27 16:00	1.56974	0.00	0.00		5.50
153565231	2012.01.27 15:00	sell	0.50	gbpsd	1.57000	1.57400	0.00000	2012.01.27 16:00	1.56993	0.00	0.00		13.50
153569465	2012.01.30 08:38	sell	0.50	gbpsd	1.57027	1.57440	0.00000	2012.01.30 09:30	1.56953	0.00	0.00		72.00
153703393	2012.01.30 08:38	sell	0.40	gbpsd	1.57027	1.57440	0.00000	2012.01.30 09:32	1.56990	0.00	0.00		54.80

75美分账单差错



1980年代：LBL Clifford Stoll

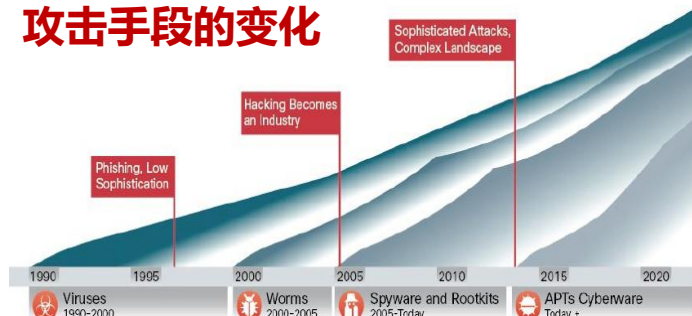


2010年代：伊朗震网

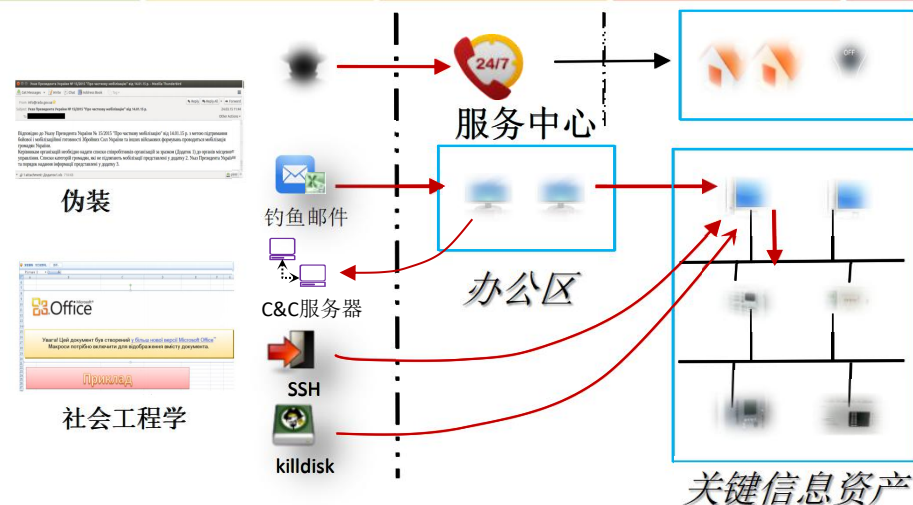
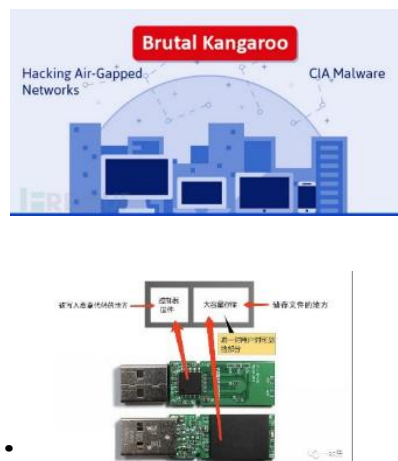
信息安全归根到底是攻击者、防御者之间资源和智能的对抗！

变化的是工具和模式

攻击手段的变化



未知威胁
智能化
协同化
速度快
处置难

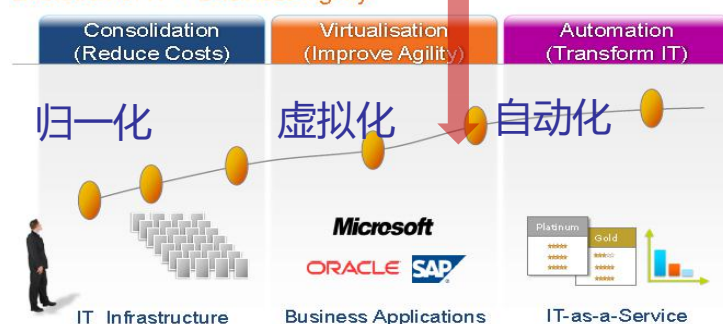


- 更多、更快、更协同、更智能、更难检测...

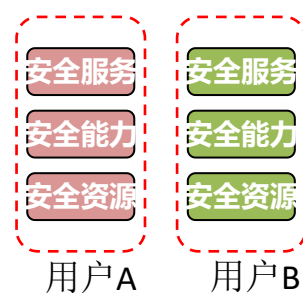
业务模式的变化

The Journey to Cloud

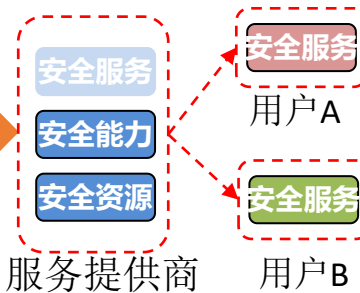
Evolution of IT + Business Agility



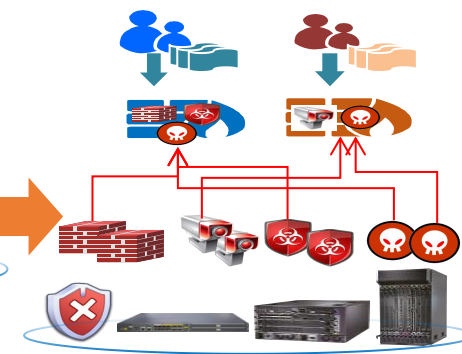
传统安全业务模型



安全服务化业务模型



NIST



- 从基础设施安全变为租户业务安全；僵化到弹性；边界到全流量；静态到动态自适应...

大数据时代，定义“资产价值”的不再是用户，而是攻击者！

不变的是趋势和规律

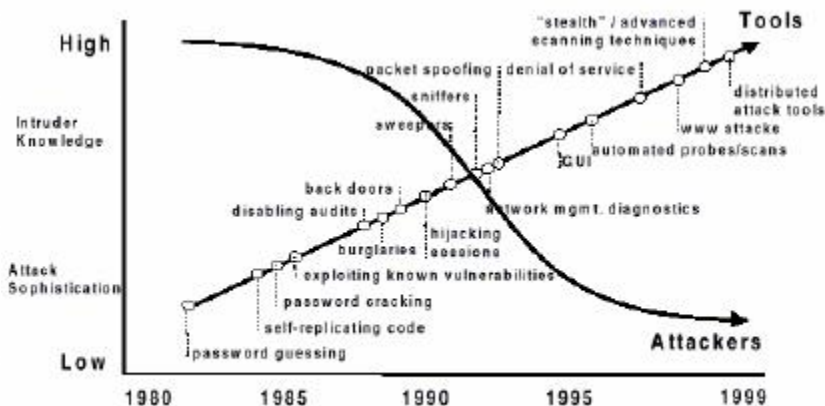
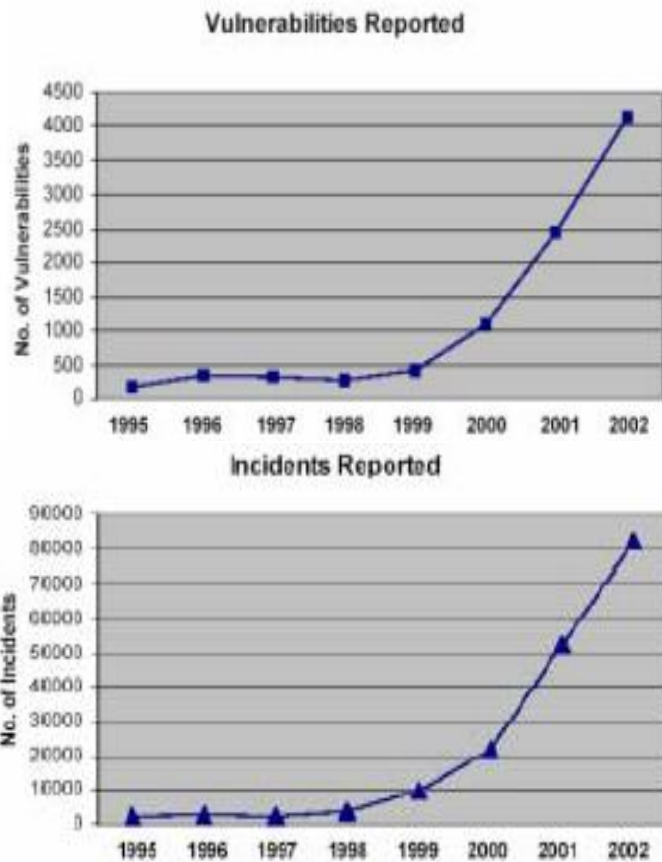
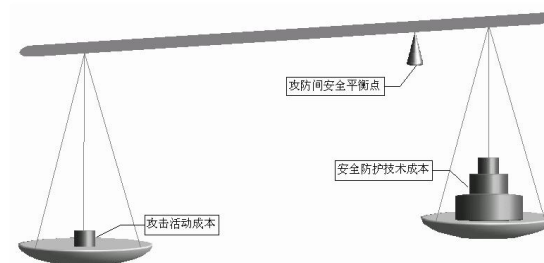
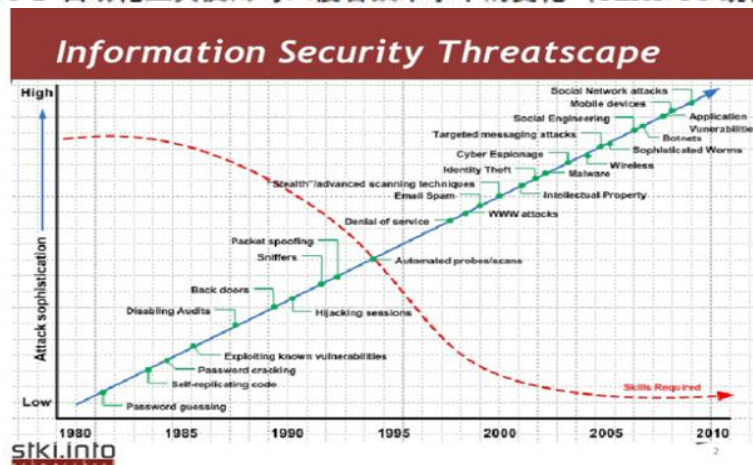


图 3-2 自动化工具使用与入侵者技术水平的变化 (CERT/CC 统计)



当前信息系统安全形势
攻防成本不平衡现象

- 修复所有漏洞，对抗所有攻击是不可能的；打碎一个花瓶总是比修复一个花瓶要容易；工具加剧了不对称趋势...

在当前开放式信息系统环境下，没有技术手段保证可以做到绝对安全！信息系统天生“易攻难守”！

目录

信息安全的变与不变

安全对抗的制胜之道

华为基于AI的云安全实践

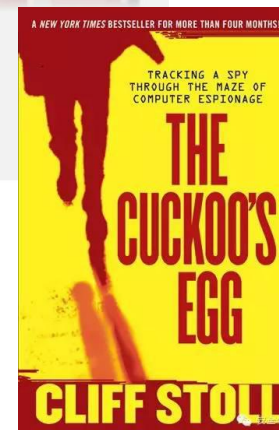
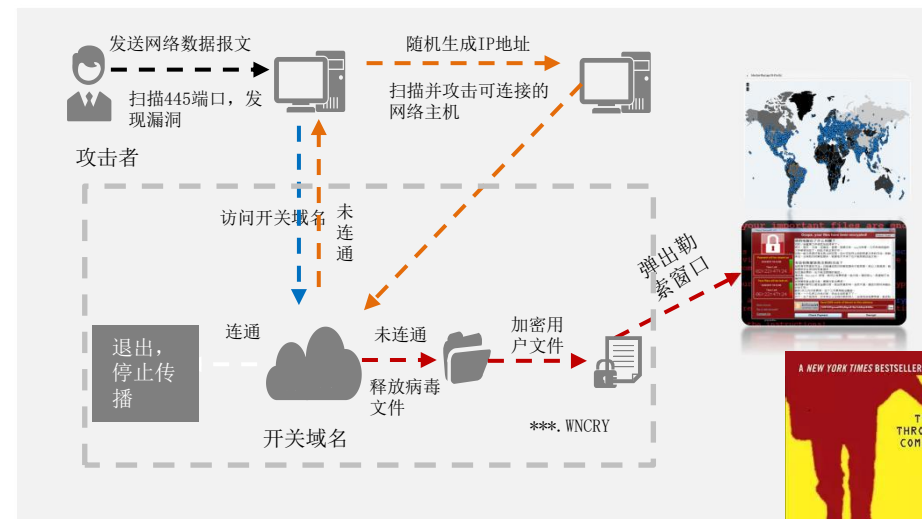
信息安全是一种信息对抗，决定成败的关键是成本



VS



- 为什么现在不再修长城？



- 攻击者害怕什么？
- 防火墙？IPS？加密？还是大数据...

要想在信息对抗中立于不败之地，只能避免在现有“不对称”环境下的直接的对抗！

安全治理是要以低成本达到“安全与威胁”间的平衡

两千年前的《孙子兵法》揭示了对抗的艺术：

- 上兵伐谋，其次伐交，其次伐兵...
- 是故百战百胜，非善之善者也；不战而屈人之兵，善之善者也
- 能而示之不能，用而示之不用，近而示之远，远而示之近...

为什么“鸳鸯阵”可以获得冷兵器时代最悬殊的战损比？



—— “隐真示假” 比硬碰硬的直接对抗更为有效！

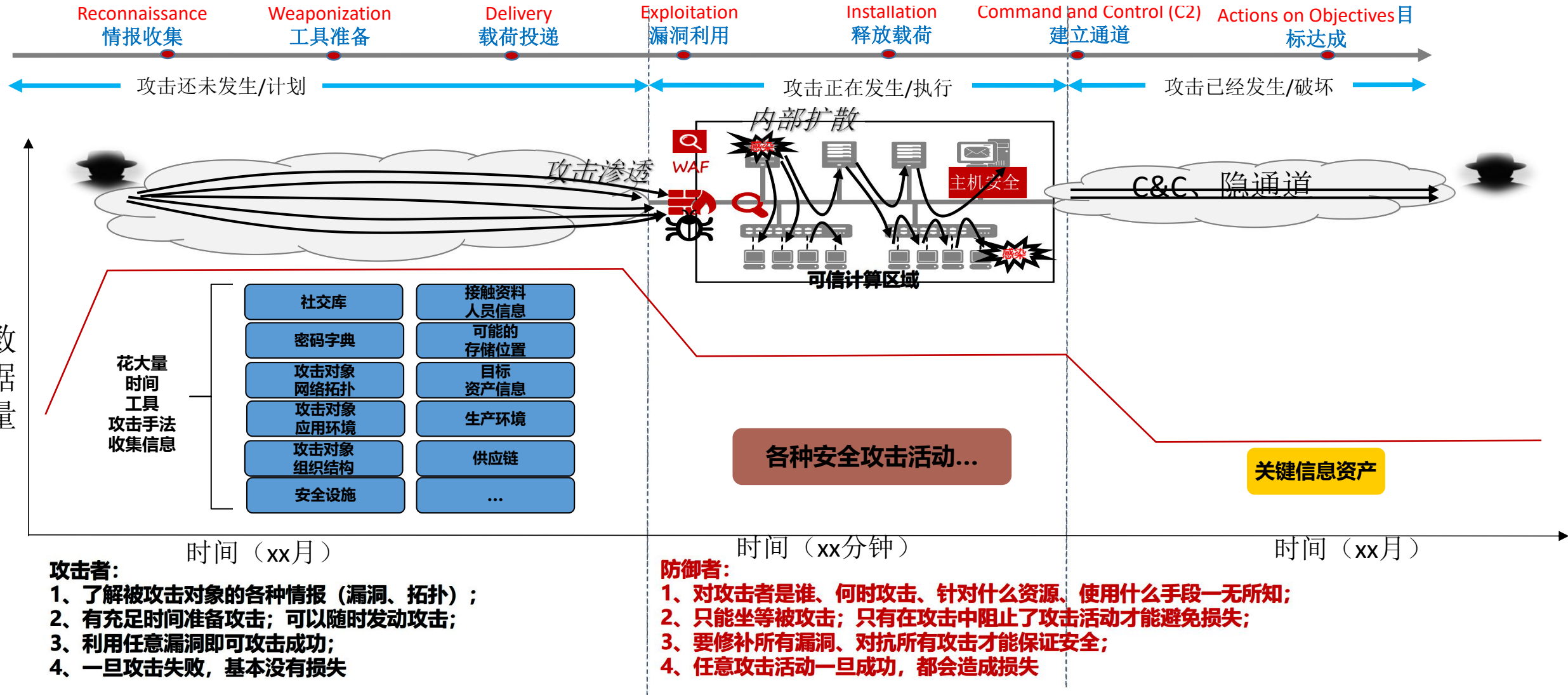
—— 建立能使攻防成本保持平衡的信息治理体系，比击败每一个攻击者更为重要！



安全对抗不是单纯比较单项能力的强弱多少，决定对抗成败的是对能力的使用“策略”；
跳出简单的“直接对抗”的思维，建立完善的信息安全治理体系，是有效的策略！

攻防不对称的原因在于信息时空与知识的不对称

攻击链:





2、安全的服务对象是“被攻击者”，安全能力的服务对象是“攻击者”。服务的内容是提供知识与防护手段。

3、安全的价值在于迅速将不安全的状态转换为安全，并尽量提高攻击成本。 对已知威胁根据风险与成本取舍。 对未知威胁提升免疫力降低风险。



5、大数据改变了安全知识挖掘的方式，从实验模拟发展到密集计算，进一步完善了安全知识的积累手段，是安全智能化的基础。

6、未来 (AI) ...



ZERO TRUST SECURITY

目录

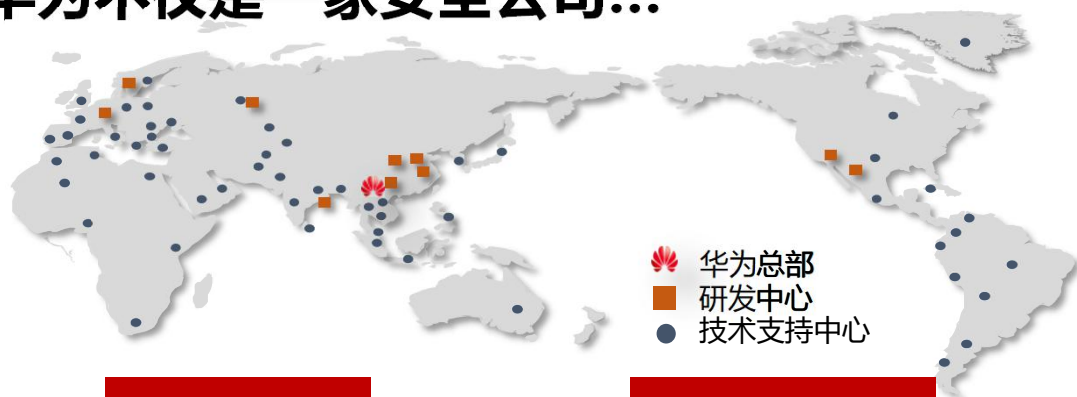
信息安全的变与不变

安全对抗的制胜之道

华为基于AI的云安全实践

华为在产业中的地位与面临的信息安全形势

华为不仅是一家安全公司...



庞大的网络

- 服务于全球**17万员工**
- 覆盖**140+国家**节点
每天处理:
- 邮件**200万封**
- 及时消息**2500万条**

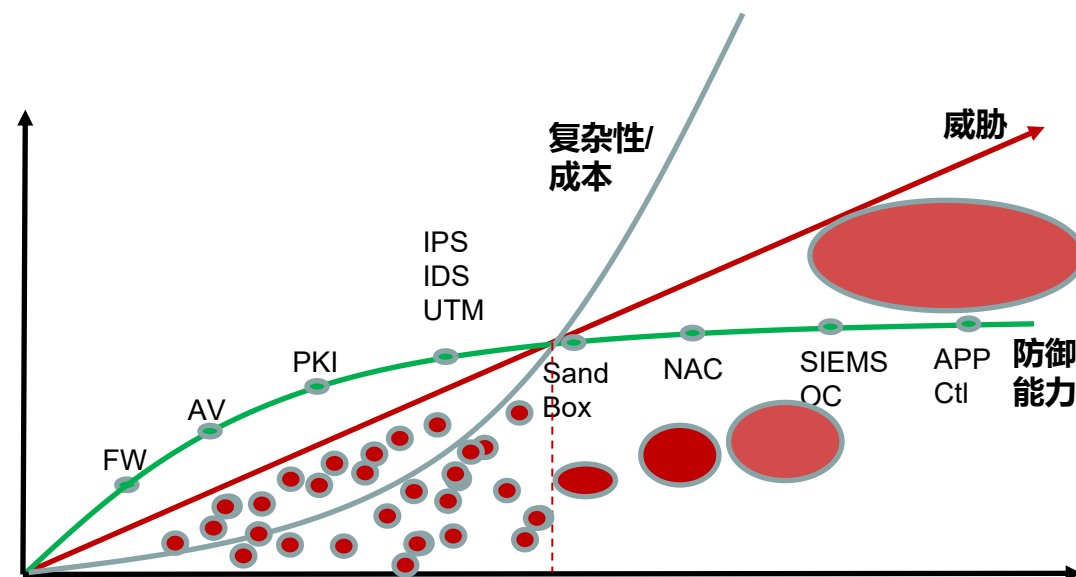
高安全的防护

- 阻断一级泄密事件**56次**
- 平均每月阻断网络威胁**49.2万次**
- 每月阻断病毒攻击**55万次**
- 阻断SQL注入/跨站攻击等**300万次/年**

i 截止2015年, 加入了300多个标准组织/产业联盟, 担任超过280个重要职位...
2015年提案5,400篇, 累计43,000余篇...

安全攻防模型: 价值决定了风险和成本...

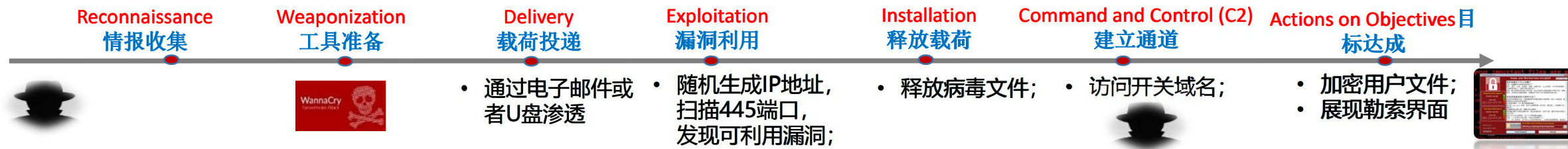
- 绝大多数的传统攻击可以被有效防御;
- 10%的高级安全威胁产生了90%的安全损失, 消耗70%的防御成本;



北京、杭州、深圳 攻防实验室/攻防演练...
2500+专职安全研究人员...
1000+安全专利...

从攻防指导思想变化，看对信息安全体系的要求

- 攻击链（洛克希德·马丁）：围绕漏洞的“发现即摧毁”；攻击难以被检测，来不及处置（逃逸、加密、协同、快速扩散）...



- 纵深防御：在攻击链各个环节，检测威胁（攻击/脆弱性），消除威胁；无法保证100%有效检测、滞后、只看到事件碎片、响应慢...



如今，在防御过程中不但要看到棋子，还要感知棋局...



安全知识的积累：

- 加强单点防御能力，层层防御：补充未知威胁检测手段/提高安全事件检测与防御概率；
- 拓展防御深度，实现尽早防御：在攻击前进行防御；

安全技能的有效应用：

- 感知全局安全态势，实现协同防御：构造完整攻击视图，实现对威胁的快速闭环；

在今天，并非把业界最强安全产品简单堆叠，就能实现对威胁的有效防御...

华为软件定义的安全解决方案

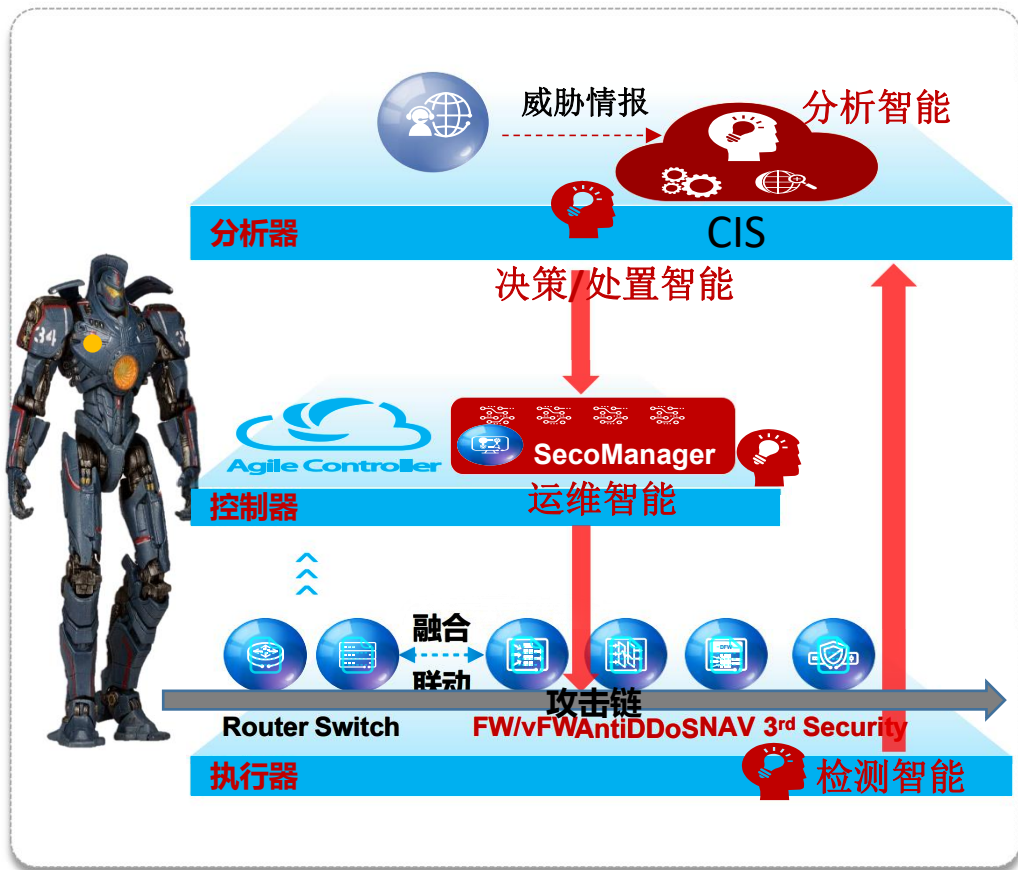


ISC 互联网安全大会



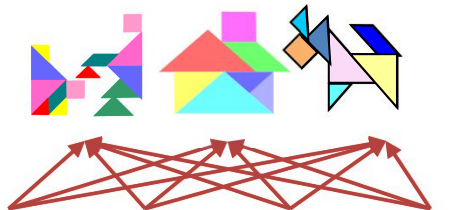
360 互联网安全中心

- **知识的积累：执行器检测/防御单项安全事件；**
- **知识的有效应用：分析器感知整体安全态势，调用控制器实现对攻击的自动化决策处置；**

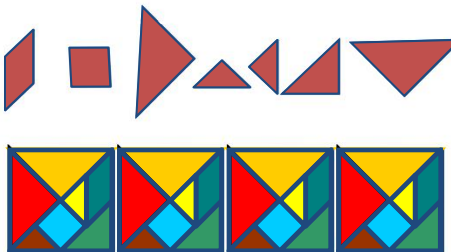


取证溯源
日志关联分析
流量异常分析
PB智能检索

CIS



SecoMgr



安全资源池

安全智能防御

- AI威胁分析/态势感知
- 安全智能联动

安全服务化/运维自动化

- 基于AI的策略管理（策略自动化）；
- 安全服务化（资源管理/业务编排）；

纵深防御/未知威胁检测

- 单点安全防御能力
- 基于AI的未知威胁检测
- 攻击前的防御
- 安全资源池化

Huawei SDsec安全解决方案=应对新型攻击的安全智能检测与联动闭环+适配业务要求的安全弹性架构...

ZERO TRUST SECURITY

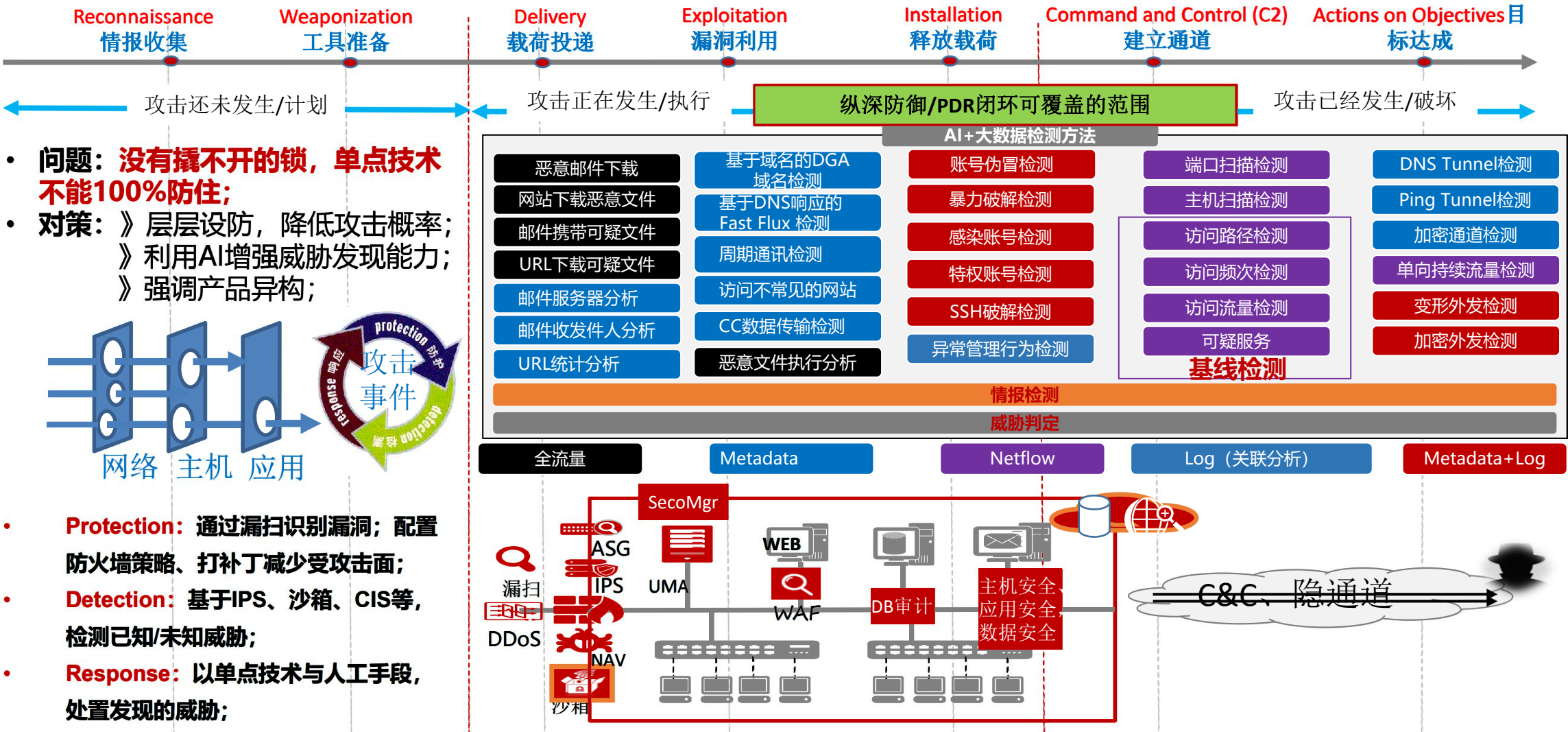
检测智能：基于AI的纵深防御能力——单点威胁检测与防御



ISC 互联网安全大会



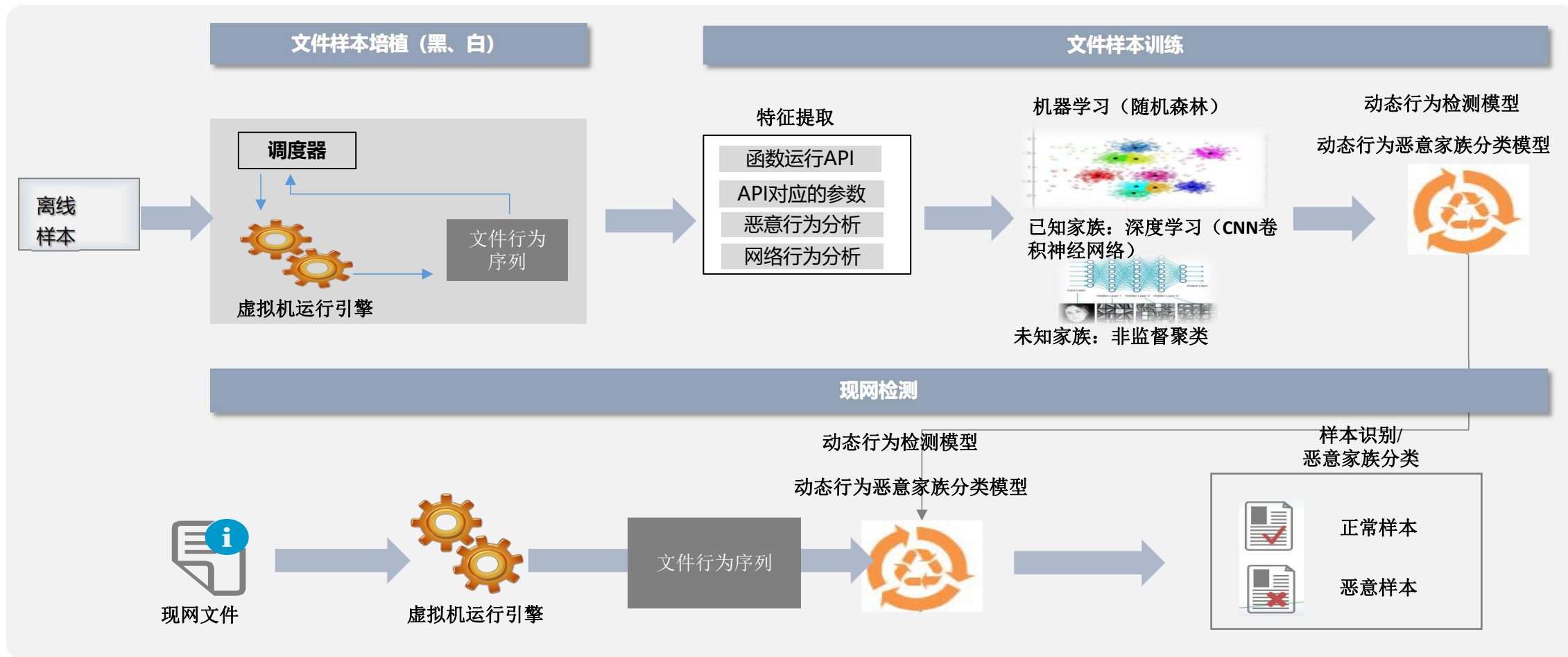
360 互联网安全中心



提供有效应对单项威胁的有效检测与防御手段！

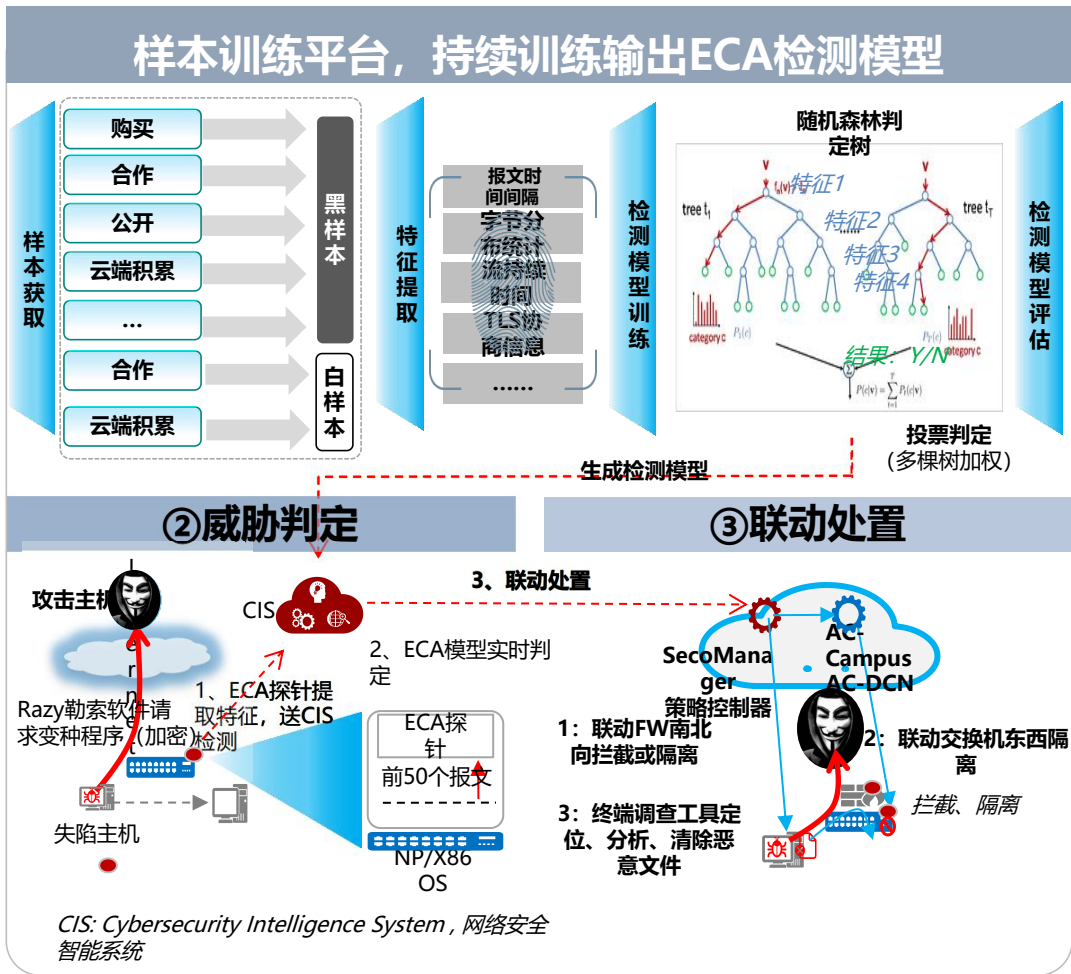
FIRHUNTER：基于HYPERVISOR+AI的恶意代码检测沙箱

- 有监督的恶意文件检测—基于动态行为的恶意判定；
- 有/无监督的恶意文件检测—基于动态行为的恶意家族分类；

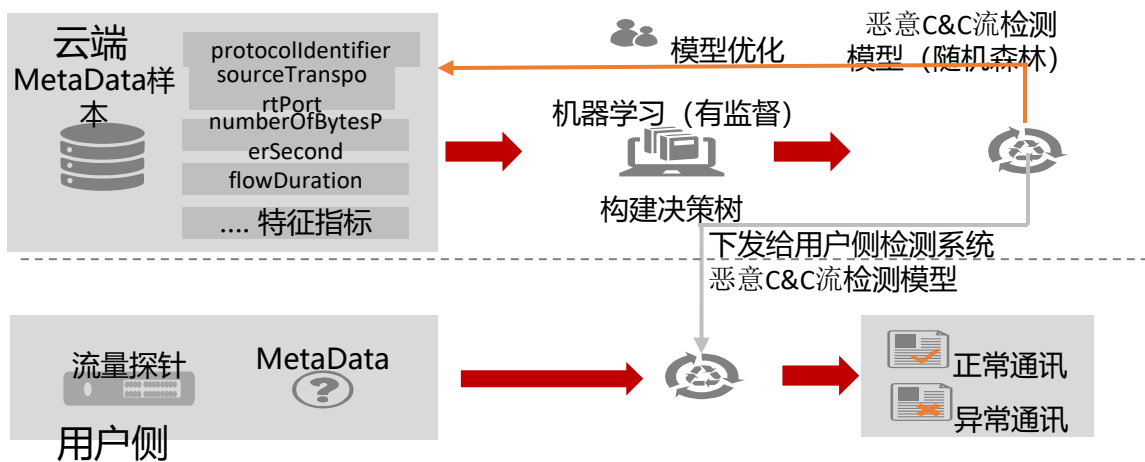


CIS: 基于AI的网络异常通信流量检测

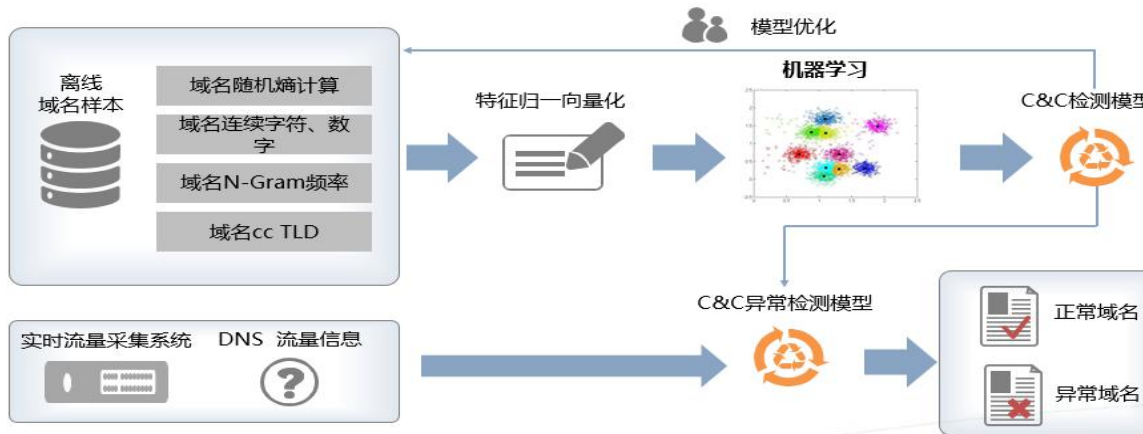
有监督学习加密流量C&C检测：ECA加密流量检测



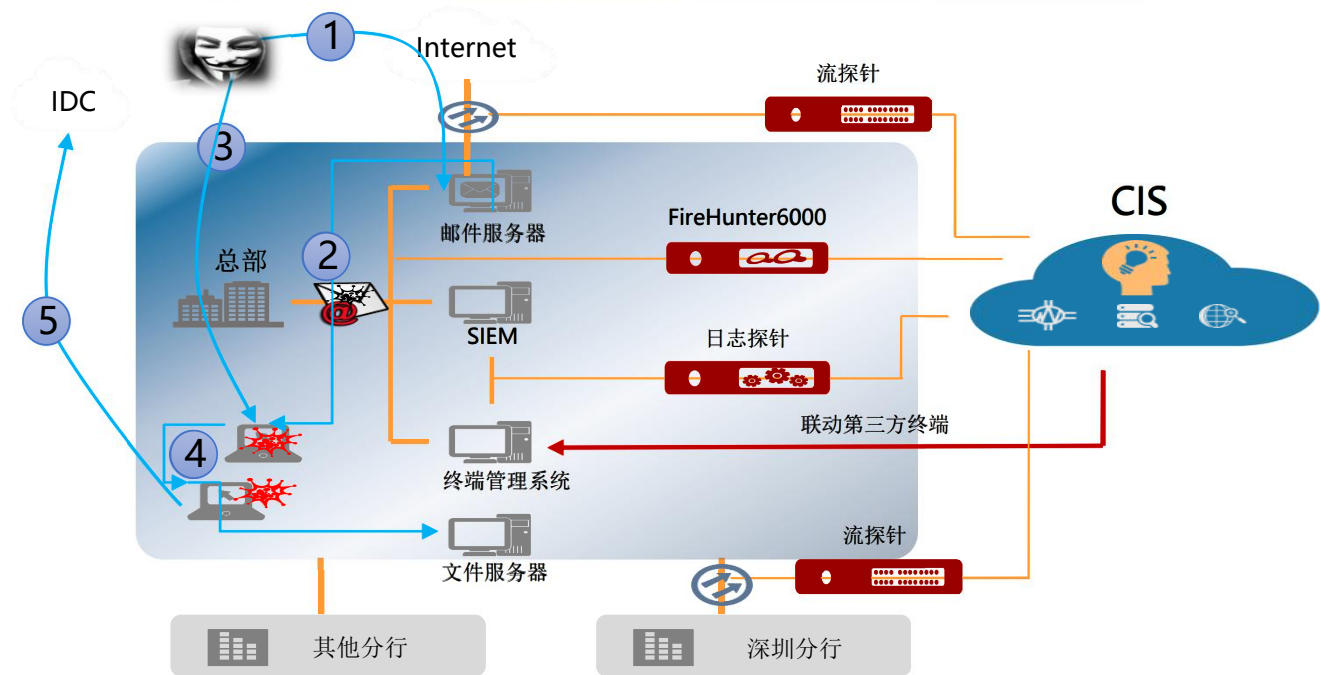
有监督恶意C&C/Webshell异常通信/DNS隐通道检测



无监督学习DNS流量C&C检测：DGA恶意软件&通讯



检测智能：CIS+沙箱——实现对单点安全威胁的智能检测



上线2月效果显著

- **载荷投递：**发现**8个全球首次发现**、19个Top4杀软、38个现网杀软无法检测的未知病毒
- **建立C&C通道：**深圳、上海、南昌、天津分行部分机器发起对12个黑客服务器的请求（美国4个、葡萄牙5个、中国1个、马来西亚1个）
- **数据外泄阶段：**检测到Ping/DNS隐蔽通道

攻击行为	阶段	检测手段	异常点
1 黑客伪造钓鱼邮件发给银行员工	渗透	文件沙箱：检测邮件附件	文件高危或可疑
2 员工执行附件感染未知病毒	渗透	流量探针：跟踪邮件下载	员工下载可疑文件
3 接收外部黑客指令	远控	流量探针	DGA（动态生成域名）、恶意C&C流、加密攻击
4 根据指令收集内部信息（高级权限、内部扩散收集数据、获得跳板机）		日志探针、NetFlow	蠕虫、暴力破解、扫描、基线
5 根据指令外发数据	数据外发	流量探针	Ping/DNS隐蔽通道

基于网络诱骗技术的攻击意图检测：对攻击者“隐真示假”

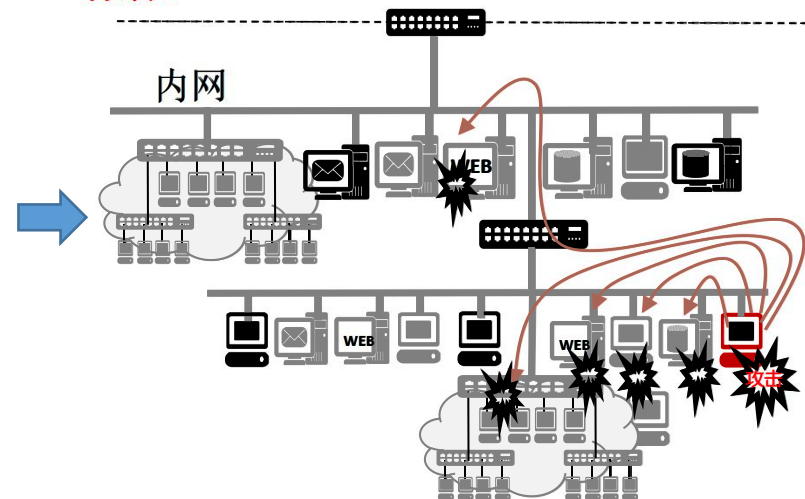
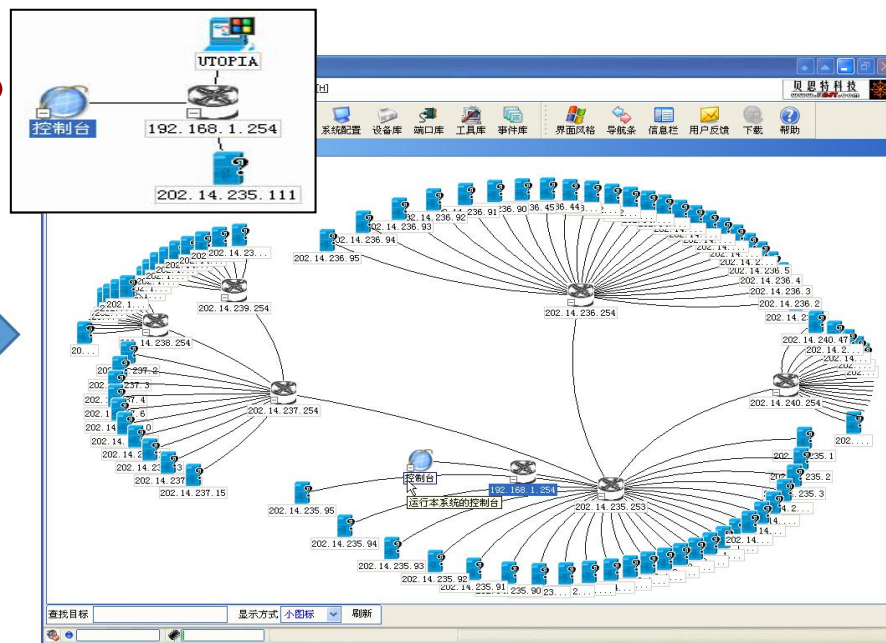
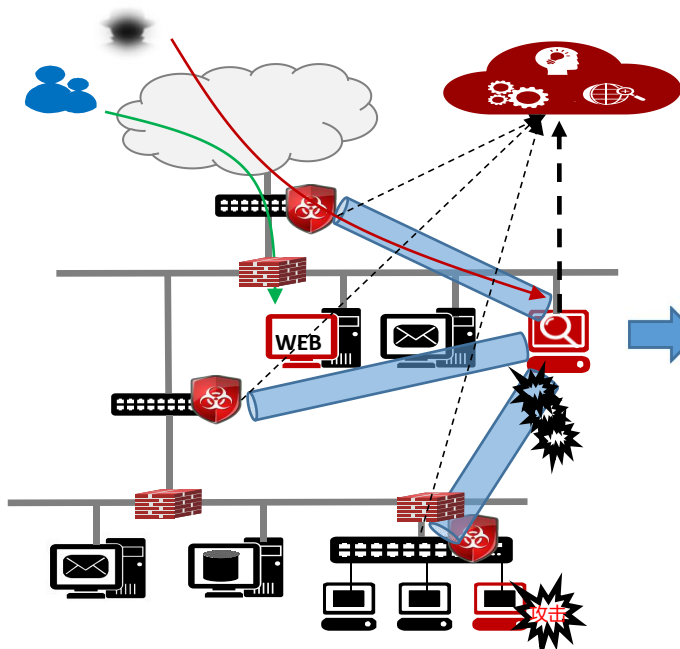


- 问题：传统纵深防御总是滞后于攻击；
- 对策：通过诱骗，识别攻击意图
 》基于意图：设置诱饵陷阱捕狼
- 方法：网络诱捕技术



- 基于特征的检测（认识所有的狼）；
- 基于行为的检测（监控所有吃羊的行为）

- 防御原理：提供虚假信息，把攻击引入歧途，攻击者只要攻击了诱饵资源，即暴露！
- 无需逐一对抗特定攻击或者修复漏洞，普遍有效！



扩展防御深度，拓展防御的数据空间，实现在攻击破坏发生之前实现威胁检测与防御！

大数据安全智能协防：AI检测/态势感知/协同联动技术



为什么有了纵深防御还防不住APT?

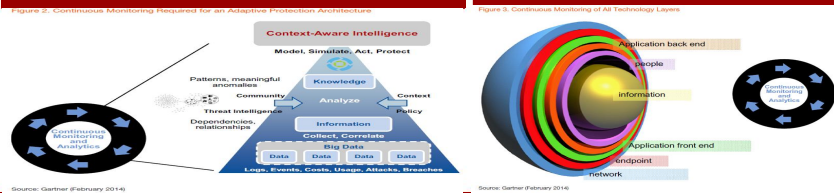
——单点防御，不能识别完整攻击链并协同防御...



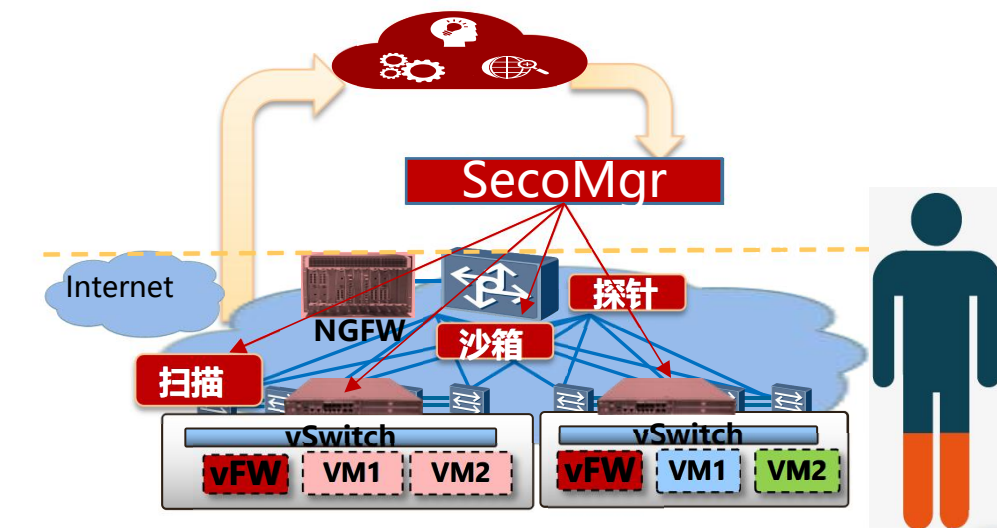
RSA 2016: FW/沙箱/SIEM的安全防御是失败策略，基于完整网络可视、机器学习和人工智能才能应对高级威胁...

自适应保护架构

持续监控所有数据

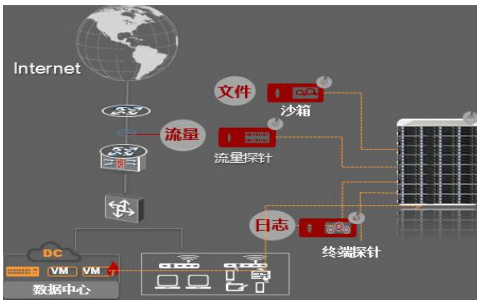


从数百万条“正常”记录中识别出“异常”攻击事件...

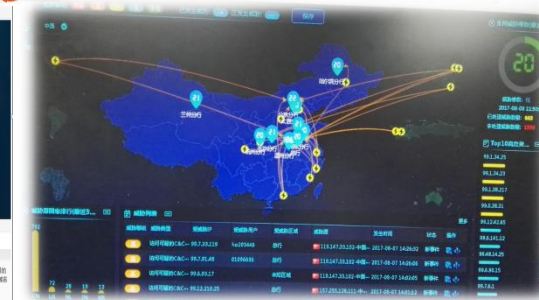
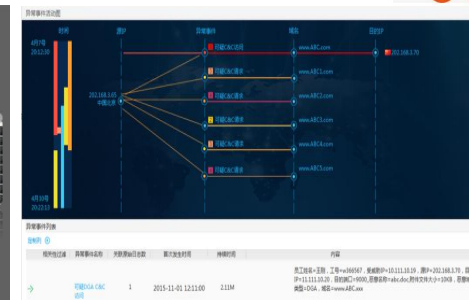


安全智能平台：
相当于人的大脑和眼睛，
提供安全协同分析和决策能力...

纵深防御技术：
相当于人的四肢，
成为安全的感应器和执行器...



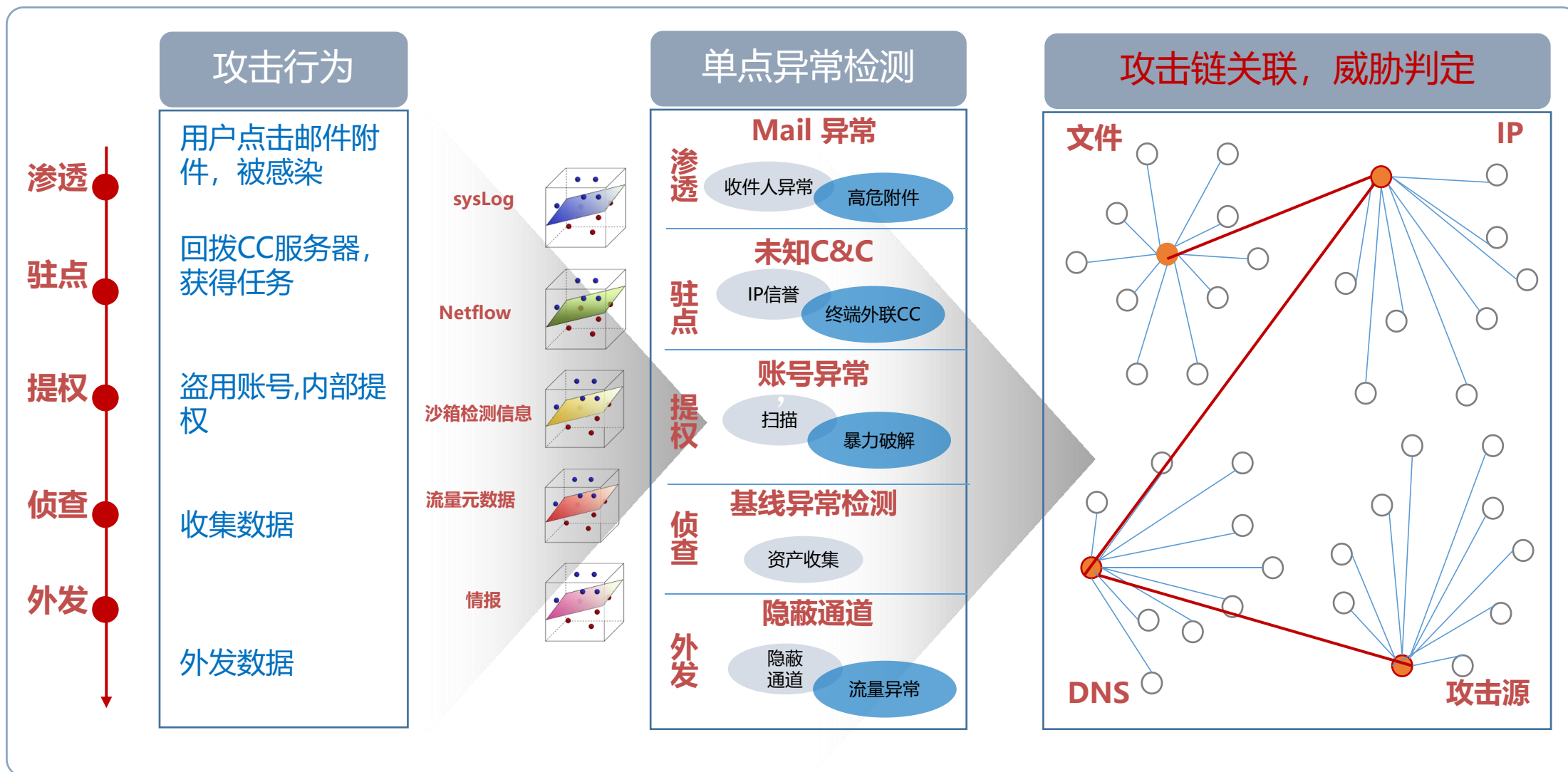
隐通道&未知攻击检测



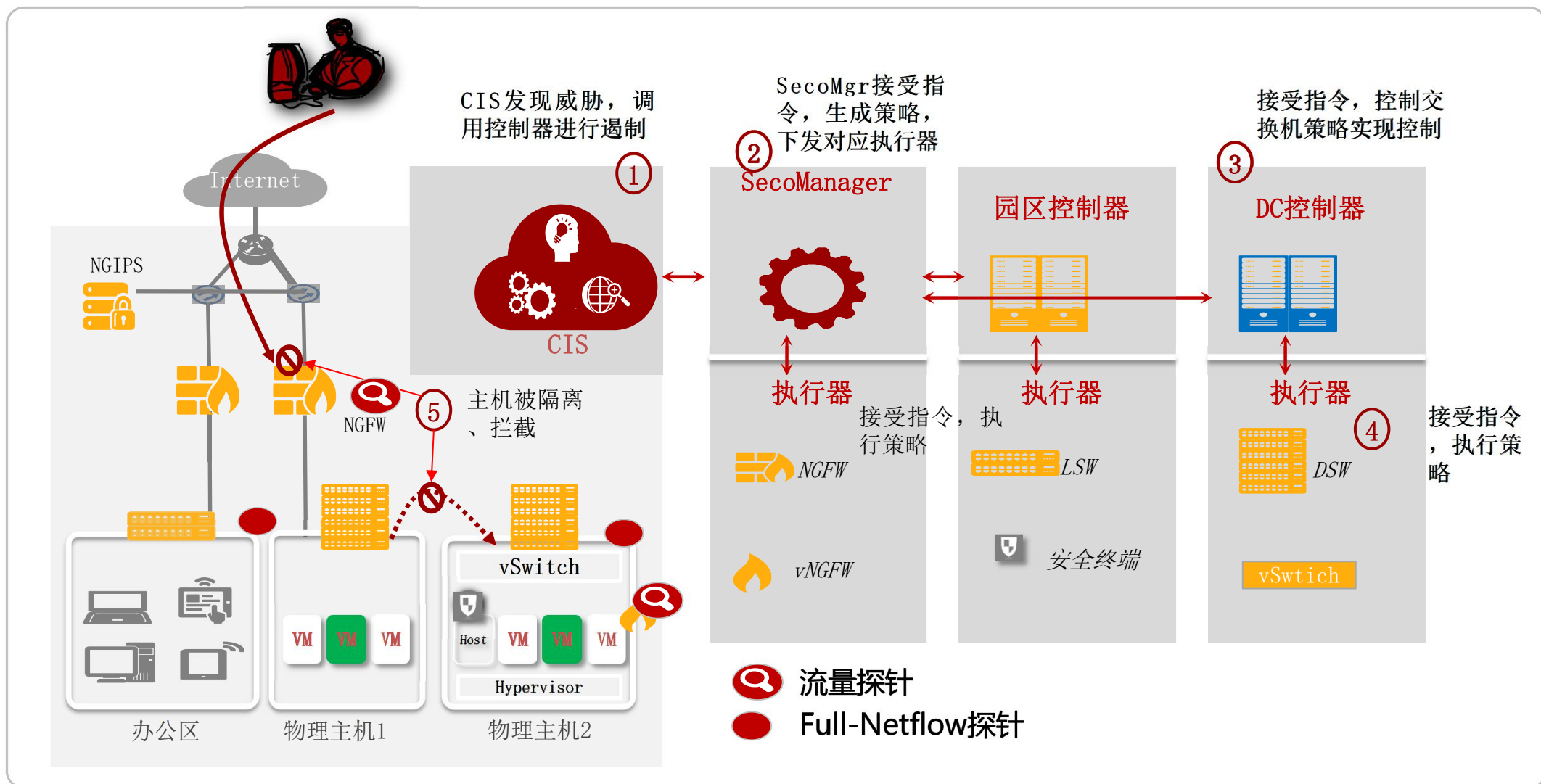
获得多维数据的统一分析能力，重构全局攻击视图；协同联动/快速闭环能力，不再强调异构。

ZERO TRUST SECURITY

AI分析智能：基于攻击链，关联判定，取证溯源，建立威慑



威胁处置智能：与SDN联动实现全网安全协防，快速处置



运维智能：基于AI实现“云/网/安”一体化策略运维

工单系统

应用管理员A:
需求1: 新建SrcIP (10.11.12.13) →DstIP (10.11.13.34) /Port (2456) 的访问关系;
需求2: 删除所有到DstIP (10.11.12.15) 的访问关系;

应用管理员B:
需求1: 新建一套应用系统, IP地址池和Port 是....., 访问关系是.....

应用管理员C:
.....

工单系统

Restful: APP
ID/IP
rule/Action/...

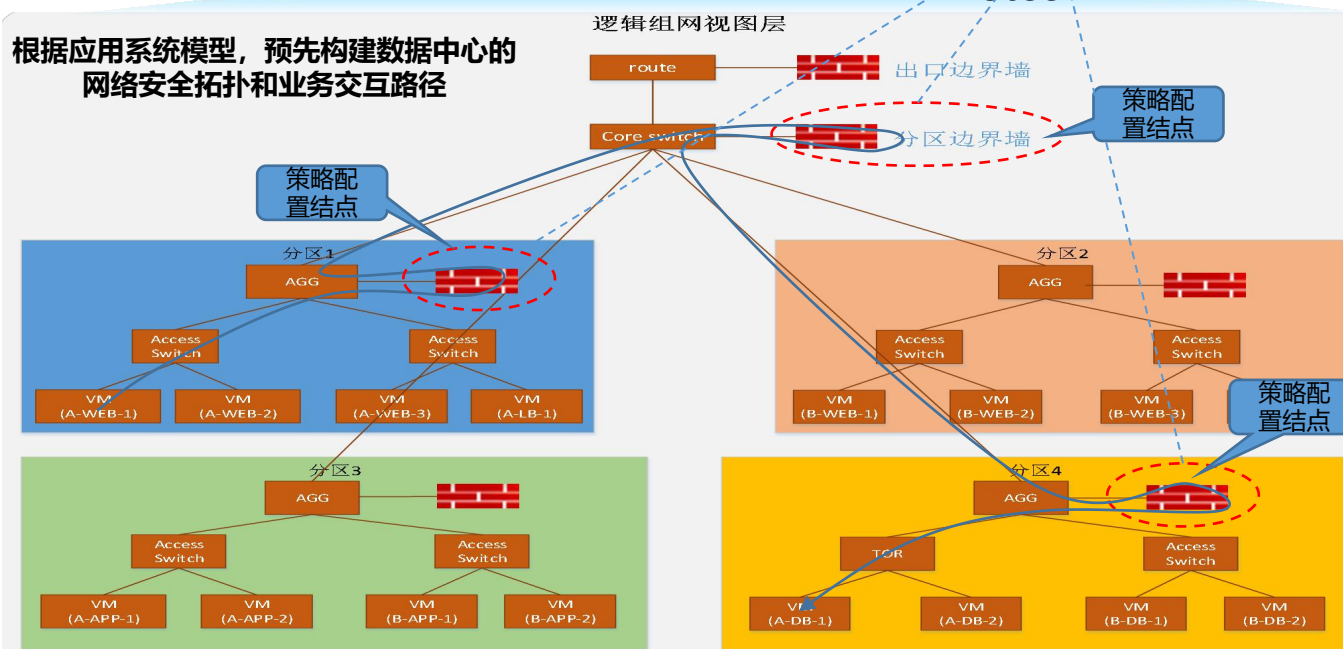
应用定义和变更

SecoManager

- ✓ 网络分区架构
- ✓ 策略编排、优化
- ✓ 应用依赖关系可视
- ✓ 异常流量感知

Netconf

根据应用系统模型, 预先构建数据中心的
网络安全拓扑和业务交互路径



在哪些FW上配置哪些策略?

防火墙策略

Firewall-101:
rule 1 permit ip source 10.11.12.13
destination 10.11.13.34/32 port 2456
Firewall-228:
undo rule 10
Firewall-313:
undo rule 100
.....

① 不感知应用, 手动部署:
业务生命周期和安全策略缺少对应关系, 云环境业务变更频繁, 依赖手动触发上线/变更

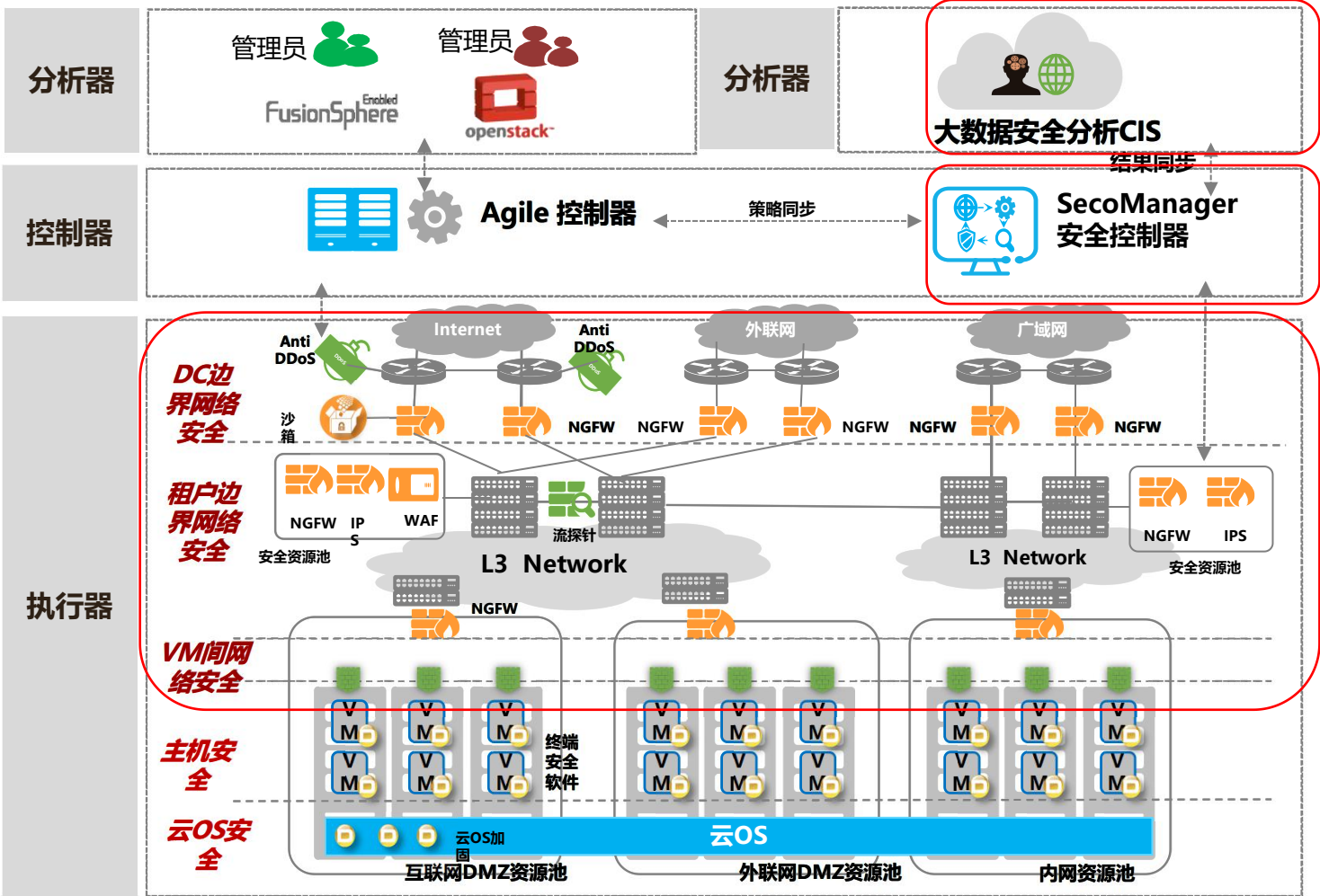
② 策略全行分散部署, IP策略语言, 难运维:
IP五元组策略, 20000+条, 维护管理带来很大难题

对接业务工单, 联动云平台/网络控制器, 实现安全业务编排, 随同业务策略的自动化安全策略运维

华为云安全解决方案全图



安全执行器、控制器、分析器构成安全智能联动框架；安全池化与策略自动化设备，构建安全弹性服务架构；



分析智能
处置智能
安全服务化
运维智能
合规的基线化安全能力
单点检测智能
意图检测
安全资源池化

华为SDSec解决方案特点：

- 从单点防御到全网协同防御；
- 从基于策略的静态防御到基于智能的动态防御；
- 从针对威胁的被动防御，到基于意图识别的主动防御；
- 早于攻击破坏实现事先防御；

架构开放：

- SDDec安全解决方案通过开放接口融到网络SDN架构中，可与不同的SDN框架和云管理平台对接
- 安全框架开放标准接口(I2NSF)，可的以容纳各种能力和不同的产品组件，构造开放共赢SDN安全生态；



ISC 互联网安全大会



360 互联网安全中心

谢谢!

2018 ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

(原“中国互联网安全大会”)